Feature

Enhancing IT Governance With a Simplified Approach to Segregation of Duties

Kevin Kobelsky, Ph.D., CISA, CA, CPA (Canada), is an assistant professor of accounting at the University of Michigan—Dearborn College of Business (USA). Prior to academia, Kobelsky was an IT audit manager in the Toronto office of Ernst & Young and the manager of internal audit at Canadian Tire Corp. His research on the impacts of IT on organizational performance, market value and internal control has been published in several leading journals including *The Accounting Review*, *Journal of Information Systems* and the *International Journal of Accounting Information Systems*. His research has been funded by the US National Science Foundation (NSF) and profiled in *InformationWeek*. He is a member of the editorial boards of the *Journal of Information Systems* and the *International Journal of Accounting Information Systems*.

Do you have something to say about this article?

Visit the *Journal* pages of the ISACA web site *(www.isaca.org/journal)*, find the article, and choose the Comments tab to share your thoughts.

Go directly to the article:

The effective design and implementation of segregation of duties (SoD) is a central topic in the governance of IT-based systems. It is one of six important characteristics to be considered in the selection and development of control activities (Principal 10's Points of Focus) in the Committee of Sponsoring Organizations of the Treadway Commission's (COSO) *Internal Control—Integrated Framework*[1] and is cited in the Public Company Accounting Oversight Board's (PCAOB) Audit Standard No. 5[2] and in the American Institute of Certified Public Accountants' (AICPA) AU 314.[3] While its objective is simple, the allocation of work so that an employee cannot both perpetrate and conceal errors or fraud,[4] its implementation is not. As has been observed, "…companies struggle with SoD compliance, and it … repeatedly stifles IT, internal audit and finance departments."[5] This is in large part due to the lack of consensus about best practices for SoD,[6] particularly for IT-related duties. This lack of consensus is clear in the segregation creep of ever-larger control matrices, identifying incompatible functions[7, 8] and the lack of development of general principles that can be applied effectively to a variety of practical settings. This is a particular problem for smaller firms in which SoD weaknesses occur in the majority of reportings of material weaknesses in internal control.[9]

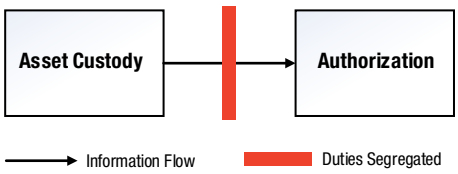
A simple, but powerful approach to identifying IT-based SoD conflicts has been developed and is based on fundamental organizational principles for control.[10] This approach allows organizations to strengthen SoD using fewer segregated duties than conventional approaches, helping small and large organizations enhance internal control and improve process efficiency and flexibility.

PRIMARY SOD: ASSET CUSTODY VS. AUTHORIZATION

To provide a conceptual foundation for SoD in IT-supported tasks, one must start with the most fundamental SoD: asset custody and authorization (**figure 1**). Absent independent authorization, employees who have custody of assets could misappropriate or reduce the value of assets without detection.

Также на русском
www.isaca.org/currentissue

Figure 1—Fundamental Segregation of Duties: Custody/Execution and Authorization



Source: Adapted from Kobelsky, K; "A Conceptual Model for Segregation of Duties: Integration Theory and Practice for Manual and IT-based Processes, *International Journal of Accounting Information Systems*, Forthcoming.

Asset custody includes duties in which, as part of a transaction, things of value to the organization are handled (physically or virtually), assigned a value or committed to, and poor performance of that duty could result in a loss to the organization. In the sales cycle, examples of these duties and related potential losses include:

- **Sales order pricing.** An example of asset valuation without physical custody, assignment of an inappropriately low price by a salesperson would result in a loss to the organization.
- **Picking and shipment of inventory.** All handling involves the risk of theft or damage by employees. Understatement of quantities input as shipped would result in a loss, while overstatement would lead to the overbilling of customers.
- **Receiving payments or other financial assets from customers,** which can be stolen, lost or inaccurately recorded

While a transaction may involve a simultaneous exchange of assets, often the selling organization

obtains a promise to receive payment. This records-based asset exists only in the records of the firm where it is vulnerable to manipulation and destruction. Employees who can enter transactions in these records are also considered to have asset custody. Examples of such duties and related threats include:

- Calculating the invoice total amount based on quantity shipped and price and recording this total in accounts receivable
- Reducing accounts receivable, both due to write-offs and payments received

Each transaction arising from these custody duties must be authorized by an independent employee having expertise or guidance sufficient to evaluate it.[11] For example, if prices for complex custom-made products in a dynamic business setting are negotiated in the field by the sales agent, the authorizer must possess sufficient knowledge to assess whether the prices are appropriate. If a price list has been preapproved, the authorizer must use this list. The authorizer should not directly or indirectly report to the asset custodian. Authorization by peers of the asset custodian is possible; however, peers can often be influenced, undermining their independence and increasing the risk of collusion. Independence is also essential in the opposite direction: The authorizer should not initiate or otherwise direct any custody transaction that he/she is responsible for authorizing. This prevents the authorizer from initiating and authorizing an inappropriate transaction with a colluding external entity.

A MODEL FOR PRIMARY SOD IN AN IT-SUPPORTED PROCESS

The introduction of IT to support a business process presents additional considerations in implementing SoD. The data associated with records-based assets and the recording of custody and authorization duties become susceptible to manipulation and loss in new ways because of the unique nature of IT-based processes. First, transaction and master file data must be input into the computer system, introducing the possibility of error. Second, these data are processed by software that will have programming errors arising from their development and maintenance or their operational execution. These data or programming errors could result in the loss of a valid transaction, an erroneous transaction or element of a transaction (e.g., an incorrect price is applied), an erroneous record of the transaction (e.g., a clerk records a lesser quantity than was actually shipped), or erroneous authorization of the transaction (e.g., an exception report omits a transaction having an inappropriate price).

Enjoying this article?

- Learn more about, discuss and collaborate on governance of enterprise IT (GEIT) and Sarbanes-Oxley in the Knowledge Center.

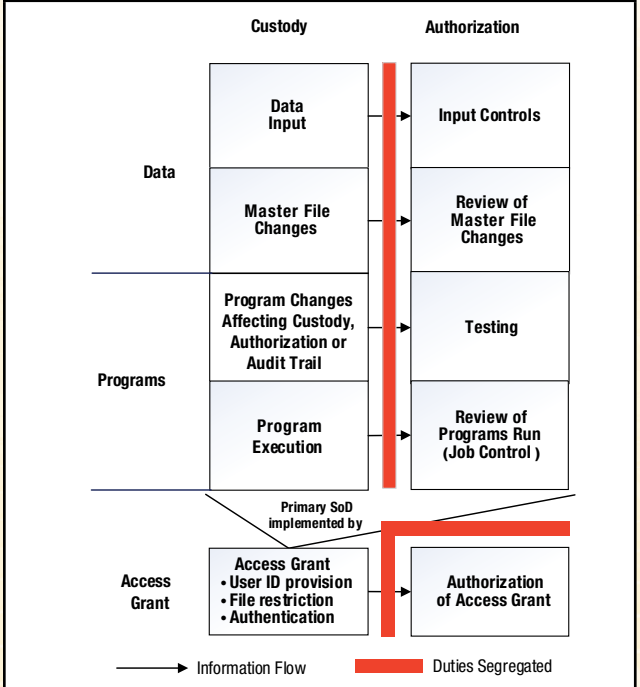
www.isaca.org/knowledgecenter

These added data and programming risk require new segregations for IT-supported processes to achieve a level of SoD on par with that depicted in **figure 1** for manual processes. Just as with physical assets, paper-records-based assets require the ability to perform custody and authorization duties. Records of performance of these duties are protected by access restrictions in manual processes to achieve primary SoD. IT-based data and the programs that modify them must also be subject to access restrictions. In manual processes, access control is physical, implemented through policies restricting access to assets, records and authorization capability, which are enforced by all employees associated with the process, including some who are independent of custody and authorization tasks. In IT-supported processes, access control is primarily virtual and inconspicuous, enforced by software mechanisms administered by IT specialists at the application, database and operating-system layers. This means extra steps must be taken with IT-supported processes to ensure that access restrictions enabling SoD are articulated fully and implemented effectively.

The approach presented in **figure 2** has two key elements:

1. It treats each of the four primary IT activities (data input, master file changes, program changes and program execution) as manifestations of the custody duty, which requires independent authorization to prevent or detect and report inappropriate transactions. For example, input of sales order data must be subject to controls to reduce the incidence of keying errors affecting pricing, quantities and other fields. Master file changes must be reviewed to ensure that they are not temporarily changed to inappropriate values for a transaction (e.g., a vendor's name and mailing address are modified before a check run so that a check is made out to an unauthorized supplier) and then changed back afterward. Similarly, all program development changes must be independently tested, and there must be adequate preventive and detective controls to ensure that only appropriate programs, such as scheduling programs and review of operations logs, have been run.

Figure 2—Primary SoD of IT-related Duties in an IT-supported Process



Source: Adapted from Kobelsky, K; "A Conceptual Model for Segregation of Duties: Integration Theory and Practice for Manual and IT-based Processes," *International Journal of Accounting Information Systems*, Forthcoming.

2. It recognizes that limiting access to data and programs provides the foundation for segregating these duties (e.g., preventing a user who changes master files from authorizing these same changes). As a result, all access grants at the application, database, operating-system and network levels must be subject to independent authorization. The access-granting duty also includes tasks that facilitate access control, such as the implementation of encryption. The access grant authorizer should not perform any other custody or authorization duties because, if he/she does and the access granter erroneously gives the access grant authorizer access to a segregated duty (e.g., a custody duty that he/she authorizes), the access grant authorizer may be tempted to not report the error because it allows him/her to misappropriate assets.[12]

It is important to note what the model does not segregate. First, data and programming-related duties can be combined. The same employee could input data, make master file changes, write and maintain programs, and be the computer operator, as long as a second independent person (perhaps his/her supervisor) performs input controls; approves master file, program and program schedule changes; and reviews the log of programs run in production. As with non-IT duties, these controls can prevent fraudulent transactions if input controls and approvals are required before changes can be implemented. Further, with the exception of authorization of access grants, the duties described in **figure 2** do not need to be segregated from end-user custody and authorization tasks, so long as each end-user custody task is independently authorized. This is contrary to the commonly recommended practice of segregating the IT functions (i.e., development, testing and operations) from user departments and data entry from program changes.[13]

Second, the access-granting duty can be combined with any of the custody or authorization duties, including program execution, so long as an independent third person authorizes access grants. This also is contrary to some recommendations calling for segregating the database administrator (DBA) function from user departments and the IT security function from the rest of the IT function.[14] In the model, only the authorization of access grants as performed at all layers, including physical, application, database, operating system and network, and not the access grant function itself, must be separated from all other duties. This is necessary so that the authorizer of access grants does not authorize changes to his/her own access levels, which would compromise his/her independence. This could be implemented as a preventive control by having authorization required prior to the access grant's implementation or as a detective control by having authorization obtained afterward. This means the minimum number of employees necessary to achieve a primary level of SoD in an IT-supported process is three.

This three-way segregation model allows segregations that are quite different from the traditional four-way segregation of development, testing, operations and access control. These may be more efficient and more feasible for small organizations. Since the segregation within each row in **figure 2** is evaluated independently, to enhance efficiency, the two IT employees could exchange duties within any row. For example, the model would also allow one employee to input data, change programs, and review master file changes and operations logs associated with a second employee. A second employee could make master file changes, run programs, review the input and program changes made by the first employee, and grant access to users. These access grants would need to be reviewed and authorized by a third person. Given the small amount of time

required to perform this task in smaller firms, the access grant authorization could be performed by a trusted security expert outside the organization. The only limitation to exchanging duties relates to testing programs that perform input controls for, or keep an audit trail of, data input or master file changes. In this case, testing will be compromised if it is performed by the same person who has a data-related duty because he/she will be less likely to report program errors that reduce controls over inappropriate data input or master file changes.

Like traditional approaches, the model requires the IT system to provide reliable logs of programs run and changes to data, programs and access grants. These logs should not be subject to modification by any user without leaving a trail of that modification (e.g., use of a write once, read many [WORM] device).

CONCLUSION

A central element in the governance of internal control of organizations is the adoption of a conceptual approach for evaluating segregation of duties that is rigorous, yet flexible and effective in practice. The proposed model challenges convention and allows organizations, particularly small ones, to implement a basic level of SoD more efficiently and effectively.

ENDNOTES

[1] Committee of Sponsoring Organizations of the Treadway Commission (COSO), *Internal Control—Integrated Framework*, 2013, *www.coso.org/IC.htm*

[2] Public Company Accounting Oversight Board (PCAOB), Auditing Standard No. 5, "An Audit of Internal Control Over Financial Reporting That Is Integrated With an Audit of Financial Statements," 2007, *http://pcaobus.org/Standards/Auditing/Pages/Auditing_Standard_5.aspx*

[3] American Institute of Certified Public Accountants, Audit and Attest Standards: AU Section 314.126 B15, 2006, *http://aicpa.org/*

[4] Stone, N.; "Simplifying Segregation of Duties," *Internal Auditor*, April, 2009, *www.theiia.org/intAuditor/itaudit/2009-articles/simplifying-segregation-of-duties/*

[5] Adolphson, M.; J. Greis; "A Risk-based Approach to SoD, Partnering IT and the Business to Meet the Challenges of Global Regulatory Compliance," *ISACA Journal*, vol. 5, 2009

[6] Hare, J.; "Beyond Segregation of Duties: IT Audit's Role in Assessing User Access Control Risk," *ISACA Journal*, vol. 5, 2009

[7] ISACA, *CISA Review Manual 2005*, USA, 2004, chapter 2, p. 88-91

[8] ISACA, "Best Practices to Resolve Segregation of Duties Conflicts in Any ERP Environment," 2012, *www.isaca.org/Groups/Professional-English/it-audit-guidelines/GroupDocuments/SOD*

[9] Gramling, A.; D. Hermanson; H. Hermanson; Z. Ye; "Addressing Problems With the Segregation of Duties in Smaller Companies," *CPA Journal*, July 2010, p. 30-34

[10] Kobelsky, K.; "A Conceptual Model for Segregation of Duties: Integrating Theory and Practice for Manual and IT-based Processes," *International Journal of Accounting Information Systems*, forthcoming

[11] Protiviti, "Enhancing Sarbanes-Oxley Compliance Cost-Effectiveness," *FS Insights*, vol. 2, no.5, July 2007. The segregation of custody and authorization can operate in a preventive or detective manner. If the authorization duty occurs simultaneously with the custody duty before the latter can be completed, so that the transaction can be stopped before a loss occurs, it is preventive (e.g., reconciliation of batch control data before batch input is accepted for processing). If the authorization occurs after a loss might occur, it is detective (e.g., checking prices on orders after they are accepted by salespeople). Preventive controls reduce the likelihood of perpetration of errors, while detective controls reduce the likelihood of concealment of errors. In practice, firms often find that a preventive approach is more cost-effective.

[12] It is possible that the access granter could make the error of simultaneously giving the access grant authorizer access to custody and authorization duties, which would compromise the effectiveness of the authorization. An alternative approach to ensure that authorization of access grants is handled appropriately would be to have all access grant changes for the access grant authorizer's user ID reviewed by a third person. This would allow the access grant authorizer to perform other custody or authorization duties, keeping the total number of employees required for SoD to three. This alternative is not illustrated in **figure 2** for simplicity of presentation.

[13] Singleton, T.; "What Every IT Auditor Should Know About Proper Segregation of Incompatible IT Activities," *ISACA Journal*, vol. 6, 2012

[14] *Ibid*.